# UNIVERSIDAD PRIVADA FRANZ TAMAYO

## FACULTAD DE INGENIERÍA

## CARRERA INGENIERÍA DE SISTEMAS

# SISTEMA DE GESTIÓN DE CALIDAD (SGC) BAJO ISO 9001:2015

# EMPRESA DE TELECOMUNICACIONES "TIGO BOLIVIA"

# AUDITORIA INTERNA

**Área:** Core Network y Data Centers (ACNDC)

**Sede Central:** Santa Cruz de la Sierra, Bolivia

**Documento:** Informe Técnico de Auditoría Interna de Sistemas e Infraestructura

**NORMA DE REFERENCIA:** ISO 9001:2015 – Sistemas de gestión de calidad

**ELABORADO POR:**

- Jhilian Rosario Sejas Cavero
- Camila Rayza Mendoza Vargas

**DOCENTE:** Ing. Yblin Vargas

**ASIGNATURA:** Auditoría Informática

**CBBA-BOLIVIA**

**2026**

ÍNDICE

Prólogo

1. **00 · ESCENARIO INICIAL - El SGSI de TIGO Bolivia antes de la auditoría**
2. **0.1 Contexto de la organización**
    a. *Ubicación, infraestructura crítica y alcance de operaciones (ACNDC)*
    b. *Marco regulatorio nacional: Cumplimiento de la Ley N° 164 y directrices de la ATT*
3. **0.2 ¿Qué se hizo durante los 10 meses de implementación?**
    a. *Tabla cronológica de fases del SGSI, actividades realizadas y documentos producidos*
    b. *Punto de partida metodológico y enfoque de la auditoría en caliente*
4. **01 · PLAN DE AUDITORÍA - Documento formal aprobado**
5. **1.1 Equipo auditor**
    a. *Roles, perfiles, certificaciones (Lead Auditor, CISA, Consultor Junior) y responsabilidades*
6. **1.2 Ficha del Plan de Auditoría**
    a. *Alcance detallado, criterios normativos, exclusiones técnicas y objetivos de control*
7. **1.3 Agenda de auditoría - Los 4 días de campo**
    a. *Cronograma maestro, horarios, áreas evaluadas y técnicas de auditoría aplicadas*
8. **02 · PREPARACIÓN - Revisión documental previa al campo**
9. **2.1 Inventario de documentos del SGSI revisados**
    a. *Matriz de evaluación de consistencia: Versión, estado de aprobación y vigencia operativa*
    b. *Diagnóstico previo y alertas tempranas de desviación (Gobernanza, Hardening e Inventario)*
10. **03 · EJECUCIÓN - Los 4 días de auditoría en campo**
11. **3.1 DÍA 1 - Entrevista al Gerente del Área de Core Network y Data Centers (ACNDC)**
    a. *Transcripción de diálogos técnicos y tipificación inmediata de hallazgos:*
        i. *Hallazgo NCM-01: Ausencia de revisión gerencial (Cláusula 9.3)*
        ii. *Hallazgo NCm-01: Ventanas de riesgo en la baja de personal (Control A.8.2)*

iii. *Hallazgo NCm-02: Deficiencias de cobertura en el plan de concientización (Control A.6.3)*

iv. *Hallazgo OdM-01: Omisión en el registro centralizado de incidentes menores (Control A.5.29)*

v. *Hallazgo NCM-02: Debilidades en contraseñas de sistemas heredados (Control A.8.5)*

12. **3.2 DÍA 2 MAÑANA - Inspección física del Data Center Central (Sede Santa Cruz)**

    a. *Matriz de inspección de puntos físicos críticos, niveles CMM y evidencias de campo:*

        i. *Hallazgo NCM-03 / NCM-04: Cerraduras convencionales y falta de bitácora centralizada de visitas (Control A.7.2)*

        ii. *Hallazgo NCm-03: Activos de alta densidad sin etiquetado de inventario (Control A.8.1)*

        iii. *Hallazgo NCm-04: Vulneración por exposición física de llaves de racks (Control A.7.2)*

        iv. *Hallazgo NCm-05: Capacidad de almacenamiento saturada en el NVR del CCTV (Control A.7.4)*

        v. *Hallazgo NCm-06: Falta de redundancia N+1 en climatización de precisión (Control A.7.5)*

13. **3.3 DÍA 2 TARDE Y DÍA 3 - Pruebas técnicas sobre la infraestructura de red core y sistema central de aprovisionamiento (CRM/Billing)**

    a. *PRUEBA TÉCNICA 1 - Escaneo de puertos y servicios abiertos sobre el segmento de gestión core (Control A.8.8)*

        i. *Trazas forenses de Nmap: Exposición de protocolos inseguros (Telnet puerto 23, RDP puerto 3389, FTP sin cifrar)*

    b. *PRUEBA TÉCNICA 2 - Auditoría lógica a la Base de Datos transaccional de aprovisionamiento de clientes (Control A.8.2)*

        i. *Sentencias de consulta SQL directa (SELECT) y detección de cuentas huérfanas activas de ex-empleados*

    c. *PRUEBA TÉCNICA 3 - Simulación en caliente de restauración de datos y análisis de resiliencia (Control A.8.13)*

        i. *Evaluación del RTO/RPO y detección de corrupción de tablas y ausencia de almacenamiento offsite*

14. **04 · NIVELES DE MADUREZ CMM - Resultados por control**

15. **4.1 Tabla consolidada de madurez**

    a. *Cuantificación de la efectividad del SGSI (Escala 0 a 5) frente a los controles evaluados*

16. **4.2 Métricas globales del SGSI**
    a. *Nivel CMM promedio general de la organización*
    b. *Porcentaje de conformidad con la norma ISO 27001:2022 y balance final de desviaciones*
17. **05 · FICHAS COMPLETAS DE HALLAZGOS (Casos Críticos Registrados)**
18. **Ficha de Hallazgo TIGO-ACNDC-2026-NCM-01:** *Cláusula 9.3 – Revisión por la Dirección (Nivel CMM 0)*
19. **Ficha de Hallazgo TIGO-ACNDC-2026-NCM-02:** *Control A.8.5 – Autenticación segura (Nivel CMM 1)*
20. **Ficha de Hallazgo TIGO-ACNDC-2026-NCM-06:** *Control A.8.2 – Gestión de derechos de acceso (Nivel CMM 1)*
21. **06 · EXTRACTO DEL INFORME FINAL - Resumen Ejecutivo para la Alta Dirección**
22. **6.1 Datos generales del informe**
    a. *Referencias del documento, clasificación de confidencialidad y firmas autorizadas*
23. **6.2 Resumen cuantitativo de resultados**
    a. *Gráfico analítico de hallazgos y dictamen sobre la viabilidad de la Certificación Externa*
24. **6.3 Conclusión del Auditor Líder**
    a. *Declaración formal sobre la brecha entre el diseño documental y la realidad operativa viva*
25. **6.4 Plan de Acción Correctiva (PAC) - Matriz de Resumen Operativo**
    a. *Cronograma maestro de remediación, asignación de ingenieros responsables y plazos de cierre*
26. **07 · LECCIONES APRENDIDAS Y CONCLUSIONES ACADÉMICAS**
27. **7.1 Para el Auditor de Sistemas**
    a. *El mito del cumplimiento en papel, el valor de la evidencia técnica irrefutable y la auditoría basada en la gobernanza*
28. **7.2 Para la Organización Auditada (TIGO Bolivia)**
    a. *La ciberseguridad como operación continua, la necesidad crítica de automatización por APIs y la auditoría interna como aliado preventivo de negocio*

**CASO COMPLETO**

**AUDITORÍA INTERNA ISO/IEC 27001:2022**

**EMPRESA TIGO BOLIVIA (TELECEL S.A.)**

## 00 · ESCENARIO INICIAL - El SGSI de TIGO Bolivia antes de la auditoría

### 0.1 Contexto de la organización

**TIGO Bolivia (Telecel S.A.)** es el operador privado líder en el mercado de telecomunicaciones del Estado Plurinacional de Bolivia, prestando servicios convergentes de telefonía móvil (4G/5G LTE), internet de banda ancha residencial y corporativa (HFC/FTTH) y servicios financieros móviles a través de su filial **Tigo Money**, administrando los datos y transacciones de más de 4.2 millones de usuarios a nivel nacional.

Su **Área de Core Network y Data Centers (ACNDC)**, con base de operaciones principal en la ciudad de Santa Cruz de la Sierra, gestiona la infraestructura más crítica de la compañía: el núcleo de conmutación de paquetes y circuitos móviles, la plataforma transaccional de provisión de clientes (CRM/Billing), los enlaces troncales de datos MPLS nacionales y el Data Center principal de co-ubicación.

Ante el incremento crítico de incidentes de ciberseguridad a nivel regional (ataques distribuidos de denegación de servicio - DDoS, e intentos de intrusión por Ransomware dirigidos a operadores de infraestructura crítica) y bajo las directrices de resiliencia y continuidad de servicios emitidas de forma mandatoria por la **ATT (Autoridad de Regulación y Fiscalización de Telecomunicaciones y Transportes)** alineadas con la **Ley N° 164 General de Telecomunicaciones**, la Dirección Ejecutiva de TIGO Bolivia aprobó la implementación de un Sistema de Gestión de Seguridad de la Información (SGSI) bajo el estándar internacional **ISO/IEC 27001:2022**.

El despliegue, parametrización y alineamiento técnico de este sistema tomó un periodo riguroso de 9 meses, comprendidos entre **marzo y noviembre de 2025**. Al llegar a **enero de 2026**, el SGSI registra 10 meses de maduración formal, por lo que corresponde la ejecución mandatoria de la primera **Auditoría Interna de Verificación Operativa**, en estricto cumplimiento con la **cláusula 9.2** de la norma.

### 0.2 ¿Qué se hizo durante los 10 meses de implementación?

| Período | Fase SGSI | Actividades Realizadas | Documentos Producidos |
|---|---|---|---|
| **Mes 1–2** | **Diagnóstico GAP** | Análisis técnico y operacional comparativo entre las capacidades de red vigentes y los requisitos ISO 27001:2022. Se | *Informe de Diagnóstico GAP TIGO v1.0* |

| Período | Fase SGSI | Actividades Realizadas | Documentos Producidos |
|---|---|---|---|
| | | identificaron **52 brechas críticas** asociadas al control de accesos lógicos y la visibilidad de vulnerabilidades en enrutadores del Core de red. | |
| **Mes 3** | **Alcance y Política** | Delimitación perimetral del SGSI sobre el entorno del Data Center de Santa Cruz y los sistemas de aprovisionamiento. Redacción, revisión técnica y firma de la Política General de Seguridad por el Comité Operativo. | *Política de Seguridad de la Información (PSI-TIGO v2.0)* |
| **Mes 4–5** | **Gestión de Riesgos** | Identificación y evaluación de **65 riesgos tecnológicos** de alto impacto (interrupción de enlaces core, denegación de servicio transaccional, acceso no autorizado a bases de datos). Diseño del Plan de Tratamiento de Riesgos (PTR). | *Declaración de Aplicabilidad (SoA v1.5)*<br><br>*Plan de Tratamiento de Riesgos (PTR v1.2)* |
| **Mes 6–8** | **Implementación** | Despliegue operativo, configuración técnica y estabilización de **74 controles del Anexo A**. Modificación de reglas de Firewalls, endurecimiento de credenciales e implementación de agentes de monitoreo local. | *Manuales de Procedimientos y Configuraciones Técnicas v1.1* |

| Período | Fase SGSI | Actividades Realizadas | Documentos Producidos |
|---|---|---|---|
| **Mes 9** | **Capacitación** | Talleres técnicos de concientización en seguridad operativa para ingenieros del NOC/SOC. Debido a las limitaciones de los turnos de guardia rotativos 24/7/365, **solo el 65% del personal de ingeniería asistió**. | *Registros de Asistencia y Evaluaciones de Concientización* |
| **Mes 10 →** | **AUDITORÍA** | Apertura y ejecución de la primera auditoría interna en caliente sobre los entornos de producción del Core de Red y Data Center. | *El presente informe y sus anexos de campo* |

**Punto de partida metodológico:** El equipo auditor ratifica la existencia y aprobación del cuerpo documental del SGSI. La misión crítica de esta auditoría es responder: ¿Los controles implementados operan de manera efectiva en la infraestructura viva de telecomunicaciones o el sistema se limita a un cumplimiento meramente documental? ¿Refleja la documentación la realidad técnica de TIGO Bolivia?

**01 · PLAN DE AUDITORÍA - Documento formal aprobado**

**1.1 Equipo auditor**

| Rol | Nombre | Certificación / Perfil | Responsabilidad Principal |
|---|---|---|---|
| **Auditor Líder** | Lic. María Torres | ISO/IEC 27001 Lead Auditor | Dirección general del proceso, validación de criterios de cumplimiento, moderación en reuniones técnicas y firma legal del informe. |
| **Auditor Técnico** | Ing. Carlos Rojas | CISA (Certified Information Systems Auditor - en proceso) | Ejecución de pruebas técnicas invasivas y no invasivas sobre enrutadores Core, firewalls, escaneos de red y consultas directas a |

| Rol | Nombre | Certificación / Perfil | Responsabilidad Principal |
|---|---|---|---|
| | | | bases de datos transaccionales. |
| **Auditor Junior** | Consultor UNIFRANZ | Cursando la materia de Auditoría Informática | Soporte en la revisión de logs físicos, entrevistas estructuradas a los operadores de turno, control logístico y validación de inventarios. |
| **Observador** | Ing. Daniela Vásquez | Oficial de Seguridad de la Información (CISO TIGO) | Contraparte operativa dentro de la empresa. Facilita los accesos controlados a consolas y entornos restringidos. No tiene voto en las decisiones del equipo. |

**1.2 Ficha del Plan de Auditoría**

- **Organización auditada:** TIGO Bolivia (Telecel S.A.) – Área de Core Network y Data Centers (ACNDC).
- **Norma de referencia:** ISO/IEC 27001:2022 (Sistemas de Gestión de Seguridad de la Información).
- **Período de auditoría:** 10 al 15 de junio de 2026 (4 días hábiles presenciales en oficinas centrales, equivalentes a 32 horas-auditor efectivas).
- **Alcance:** Infraestructura crítica administrada por el ACNDC: 5 Clústeres de Servidores Core principales, Red LAN/WAN de transporte interno, Sistema de Aprovisionamiento Centralizado de Clientes, Control de accesos lógicos y físicos a las salas técnicas del Data Center (Santa Cruz), Gestión de incidentes de seguridad (SOC) y Sistemas de Respaldo Corporativo (Backups).
- **Criterios de auditoría:** Norma ISO/IEC 27001:2022 • Política SI-TIGO v2.0 • Plan de Tratamiento de Riesgos v1.2 • Declaración de Aplicabilidad (SoA) v1.5 • **Ley N° 164 de Telecomunicaciones de Bolivia** • Normativas de Ciberseguridad y Resiliencia emitidas por la **ATT**.
- **Exclusiones:** Agencias comerciales de atención al cliente a nivel nacional, áreas administrativas de soporte general (Contabilidad corporativa, Recursos Humanos generales) y redes de transporte externo operadas por subcontratistas externos de torres de radiobases.

- **Objetivo principal:** Verificar la conformidad técnico-operativa del SGSI con respecto a los requisitos de la norma ISO 27001:2022 y validar la eficacia operativa real de los controles de seguridad del Anexo A en la infraestructura de producción de TIGO Bolivia.
- **Entregable:** Informe Final de Auditoría con la clasificación de hallazgos, evaluación del Modelo de Madurez de Capacidades (CMM) por control y Plan de Acción Correctiva (PAC).
- **Comunicación previa:** Plan de auditoría remitido a la Gerencia del ACNDC el 5 de enero de 2026. Aprobado y firmado por la dirección el 8 de enero de 2026.

### 1.3 Agenda de auditoría - Los 4 días de campo

| Día | Fecha | Horario | Actividad Evaluada | Participantes Clave | Técnica de Auditoría |
|---|---|---|---|---|---|
| **1** | Lun 20 | 08:00–09:30 | **Reunión de Apertura:** Presentación formal del equipo, validación del alcance, confirmación de canales de escalación y reglas de seguridad técnica en caliente. | Todo el Equipo Auditor + Gerente de Core Network | Entrevista Estructurada / Acta de Inicio |
| **1** | Lun 20 | 09:30–12:00 | **Revisión Documental Base:** Evaluación cruzada de consistencia entre la Política SI-TIGO v2.0, el SoA v1.5 y el PTR v1.2. | Auditor Líder + Documentalista del SGSI TIGO | Inspección y Análisis Documental |
| **1** | Lun 20 | 14:00–17:00 | **Inventario de Activos Críticos de Red:** Cotejo físico e informático de la lista maestra de enrutadores, switches de núcleo y servidores blade contra la topología de red real. | Auditor Junior + Administrador de Infraestructura TI | Conciliación Documental + Observación Directa |

| Día | Fecha | Horario | Actividad Evaluada | Participantes Clave | Técnica de Auditoría |
|---|---|---|---|---|---|
| **2** | Mar 21 | 08:00–10:00 | **Inspección Física del Data Center Central:** Verificación de perímetros de seguridad, sistemas contra incendios, climatización y redundancia de suministro eléctrico. | Auditor Líder + Auditor Técnico + Jefe de Operaciones DC | Inspección Física In Situ (Lista de Chequeo) |
| **2** | Mar 21 | 10:00–12:00 | **Control de Accesos Físico y Lógico:** Revisión de políticas de aprovisionamiento de cuentas, procesos de revocación de credenciales y bitácoras de accesos a consolas centralizadas. | Auditor Técnico + Administrador de Identidades (IAM) | Muestreo Estadístico de Logs + Pruebas de Sistema |
| **2** | Mar 21 | 14:00–17:00 | **Auditoría de Infraestructura de Red:** Evaluación de configuraciones de Firewalls de núcleo, segmentación de redes corporativas/producción y análisis de puertos abiertos. | Auditor Técnico + Ingeniero Senior de Seguridad de Red | Escaneo Técnico Activo / Pruebas de Penetración |
| **3** | Mié 22 | 08:00–10:30 | **Evaluación del Sistema de Aprovisionamiento (CRM/Billing):** Auditoría lógica a la base de datos central de clientes, cuentas | Auditor Técnico + Database Administrator (DBA) Core | Consultas SQL Directas + Verificación de Hardening |

| Día | Fecha | Horario | Actividad Evaluada | Participantes Clave | Técnica de Auditoría |
|---|---|---|---|---|---|
| | | | con privilegios de ejecución de comandos (*Superusers*) y logs transaccionales. | | |
| **3** | Mié 22 | 10:30–12:00 | **Gestión de Incidentes de Seguridad (SOC):** Revisión de alertas en el SIEM, tiempos de respuesta (SLA), flujos de escalación y reportes de mitigación ante ataques volumétricos. | Auditor Líder + Responsable del SOC de TIGO | Entrevista + Inspección de Casos (Tickets) |
| **3** | Mié 22 | 14:00–17:00 | **Continuidad y Respaldo de Datos (Backups):** Ejecución controlada en caliente de una prueba de restauración de datos del sistema de cobros. Evaluación de cifrado y planes de concientización. | Todo el Equipo Auditor + Administrador de Almacenamiento | Prueba de Recuperación Activa + Entrevistas |
| **4** | Jue 23 | 08:00–11:00 | **Consolidación Interna de Hallazgos:** Correlación de evidencias recolectadas en campo, asignación de niveles CMM y tipificación de No Conformidades. | Equipo Auditor Completo | Análisis de Gabinete (Sesión Privada) |

| Día | Fecha | Horario | Actividad Evaluada | Participantes Clave | Técnica de Auditoría |
|---|---|---|---|---|---|
| **4** | Jue 23 | 11:00–12:00 | **Reunión de Cierre:** Presentación ejecutiva de los hallazgos críticos detectados preliminarmente a la Gerencia de Core Network y Dirección de Tecnología. | Todo el Equipo Auditor + Directivos de TIGO Bolivia | Presentación Oral + Firma de Minuta de Cierre |
| **4** | Jue 23 | 14:00–17:00 | **Redacción del Borrador del Informe:** Estructuración y tipificación formal de las fichas de hallazgos y el Plan de Acción Correctiva. | Auditor Líder | Documentación Técnica Estándar |

**02 · PREPARACIÓN - Revisión documental previa al campo**

Antes de interactuar con la infraestructura en los laboratorios y salas de racks en Santa Cruz, el equipo auditor ejecutó una revisión estricta de consistencia documental sobre los artefactos provistos por la oficina del CISO.

**2.1 Inventario de documentos del SGSI revisados**

| Documento del SGSI | Versión | Estado de Aprobación | ¿Vigente Operativamente? | Observación Detallada del Auditor |
|---|---|---|---|---|
| **Política de Seguridad de la Información (PSI)** | v2.0 | Aprobado por el Comité de Dirección en Octubre 2025 | **Sí** | El documento se encuentra correctamente estructurado y alineado con la alta dirección. Difundido en los canales corporativos |

| Documento del SGSI | Versión | Estado de Aprobación | ¿Vigente Operativamente? | Observación Detallada del Auditor |
|---|---|---|---|---|
| | | | | internos. **CONFORME.** |
| **Declaración de Aplicabilidad (SoA)** | v1.5 | Aprobado por la Dirección de Tecnología en Septiembre 2025 | **Sí** | Evalúa los 93 controles de la estructura ISO 27001:2022. Identifica **74 controles como aplicables** al área central de red y 19 exclusiones justificadas por externalización de servicios. **CONFORME.** |
| **Plan de Tratamiento de Riesgos (PTR)** | v1.2 | Aprobado en Septiembre 2025 | **Sí** | Mapea formalmente los 65 riesgos tecnológicos identificados. Requiere validación cruzada en campo para verificar el despliegue técnico real de los controles de mitigación. |
| **Inventario de Activos de Red e Infraestructura Core** | v1.1 | Emitido en Julio 2025 | ⚠ **Parcial** | **Alerta de Desactualización:** El documento no registra las expansiones de los módulos core de enrutamiento |

| Documento del SGSI | Versión | Estado de Aprobación | ¿Vigente Operativamente? | Observación Detallada del Auditor |
|---|---|---|---|---|
| | | | | troncal de Fibra Óptica ejecutadas a nivel nacional durante diciembre de 2025. **[Posible No Conformidad Menor - Control A.8.1]** |
| **Procedimiento de Control de Accesos Lógicos** | v1.0 | Autorizado en Agosto 2025 | **Sí** | El documento describe conceptualmente el flujo de asignación de permisos, pero carece de anexos técnicos que demuestren bitácoras periódicas de depuración automática de cuentas inactivas. **[Verificar exhaustivamente en campo]** |
| **Procedimiento de Operación y Gestión de Incidentes del SOC** | v1.0 | Autorizado en Agosto 2025 | **Sí** | Existe la estructura de clasificación de alertas en papel. No obstante, no se evidencia la consolidación operativa de incidentes |

| Documento del SGSI | Versión | Estado de Aprobación | ¿Vigente Operativamente? | Observación Detallada del Auditor |
|---|---|---|---|---|
| | | | | menores históricos dentro de las métricas presentadas. |
| **Plan Anual de Capacitación y Concientización en Seguridad** | v1.0 | Emitido en Junio 2025 | ⚠ **Parcial** | **Brecha de Cobertura:** Los registros de control muestran que únicamente el **65% del personal de operaciones del NOC/SOC** completó las sesiones de capacitación presencial. No se diseñó ni ejecutó un plan de recuperación para el personal ausente por turnos de noche. **[Posible No Conformidad Menor - Control A.6.3]** |
| **Actas de Revisión del Desempeño del SGSI por la Alta Dirección** | — | **No documentado** | ✕ **No existe** | **Alerta Crítica:** No existe ninguna evidencia, acta firmada o minuta de reunión que certifique que el Comité Ejecutivo de TIGO Bolivia haya evaluado el |

| Documento del SGSI | Versión | Estado de Aprobación | ¿Vigente Operativamente? | Observación Detallada del Auditor |
|---|---|---|---|---|
| | | | | rendimiento, incidentes y objetivos del SGSI desde su despliegue formal. **[Alerta Directa de No Conformidad Mayor - Cláusula 9.3]** |
| **Estándares de Configuración Segura (Hardening) de Infraestructura Core** | — | **No documentado** | ✕ **No existe** | **Alerta de Omisión:** No existen plantillas técnicas estandarizadas ni guías obligatorias escritas para el aseguramiento técnico y cierre de puertos de enrutadores y switches troncales de la marca proveedora. **[Alerta de No Conformidad Mayor - Control A.8.8]** |

**Diagnóstico previo al ingreso a campo:** La fase de preparación documental permite al equipo auditor estructurar una estrategia de ataque enfocada en riesgos reales. Antes de iniciar las pruebas, ya se han pre-identificado fallas estructurales: ausencia de revisión gerencial (Cláusula 9.3), falta de directrices técnicas de Hardening (Control A.8.8), desactualización de inventario crítico (Control A.8.1) y brechas en la concientización del personal técnico operativo (Control A.6.3).

**03 · EJECUCIÓN - Los 4 días de auditoría en campo**

### 3.1 DÍA 1 - Entrevista al Gerente del Área de Core Network y Data Centers (ACNDC)

- **Fecha y Hora:** Lunes 20 de enero 2026 – 08:02 a 09:28 hrs.
- **Entrevistado:** Ing. Pedro Quispe (Gerente de Infraestructura de Core Network - TIGO Bolivia).
- **Auditor Interrogador:** Lic. María Torres (Auditor Líder).
- **Modo:** Presencial en Oficina de Gerencia Core, Santa Cruz. Grabación de audio autorizada por las partes.

A continuación, se transcribe el diálogo técnico y directo sostenido durante la sesión de campo, con la respectiva tipificación inmediata realizada por el equipo auditor:

**AUDITOR LÍDER:** Ing. Quispe, en cumplimiento con el estándar internacional, la norma exige la rendición de cuentas del desempeño del sistema hacia los niveles ejecutivos más altos de la compañía. ¿Cuándo fue la última fecha en que el Comité de Dirección o la Gerencia General de TIGO Bolivia evaluó formalmente el estado de los objetivos, métricas e incidentes de este SGSI?

**Ing. 1:** A ver... Nosotros generamos tableros mensuales consolidados con la disponibilidad operativa de los enlaces troncales y los intentos de ataques volumétricos mitigados por el sistema anti-DDoS, los cuales se envían por correo electrónico al Comité Operativo de Tecnología. Sin embargo, si se refiere a una sesión formal de Directorio, con una agenda enfocada puramente en evaluar la efectividad y madurez del SGSI bajo la norma ISO 27001... para ser sincero, no se ha agendado ni ejecutado ninguna reunión de ese tipo hasta el momento. Cada jefe de área revisa sus plataformas de manera aislada.

**Clasificación del Auditor: No Conformidad Mayor (NCM)**. La cláusula 9.3 de la norma ISO/IEC 27001:2022 estipula de forma mandatoria que la Alta Dirección debe revisar el SGSI de la organización a intervalos planificados para asegurar su idoneidad, adecuación y eficacia continuas. La ausencia absoluta de actas de revisión gerencial constituye un fallo estructural. **ID del Hallazgo: NCM-01.**

**AUDITOR LÍDER:** Pasemos al control operacional de accesos lógicos sobre las plataformas de aprovisionamiento de servicios de red. Cuando un ingeniero de redes de nivel 3 (L3) o un administrador de sistemas de la CSR/Core presenta su renuncia voluntaria o es desvinculado de TIGO Bolivia, ¿cuál es el procedimiento técnico y el tiempo estricto establecido para revocar de forma definitiva sus credenciales de acceso a la infraestructura viva?

**Ing. 1:** Bueno, el flujo tradicional consiste en que el supervisor directo del empleado que se retira abre un ticket en la mesa de ayuda interna solicitando la baja de sus cuentas. Por lo general, los operadores de soporte procesan esa solicitud e inhabilitan sus accesos en el Active Directory y en los servidores de autenticación TACACS+ en el transcurso de las siguientes 48 a 72 horas hábiles. Actualmente, no tenemos un acuerdo de nivel de servicio (SLA) mandatorio automatizado ni una interconexión de software directa con la base de datos de bajas de la Gerencia de Capital Humano que fuerce el bloqueo inmediato de forma síncrona.

**Clasificación del Auditor: No Conformidad Menor (NCm)**. Existe el procedimiento general, pero carece de un SLA estricto y de mecanismos automatizados para garantizar la revocación inmediata de los derechos de acceso sobre infraestructura crítica nacional tras la desvinculación, generando una ventana transitoria de alto riesgo de sabotaje o exfiltración. Afecta directamente al **Control del Anexo A.8.2** (Gestión de derechos de acceso). **ID del Hallazgo: NCm-01.**

**AUDITOR LÍDER:** Respecto al Plan Anual de Capacitación y Concientización en Seguridad ejecutado a mediados de la gestión pasada, las listas master de asistencia reportan la participación de solo 9 de los 15 ingenieros que integran el equipo técnico del ACNDC. ¿Qué acciones de contingencia se desplegaron para asegurar que el 100% del personal que interactúa con el núcleo de red conozca los riesgos y controles implementados?

**Ing. 1:** El problema que tuvimos es que la sesión principal de capacitación técnica se programó en turnos diurnos a mediados de junio. En esas fechas, dos de nuestros ingenieros senior se encontraban en comisión de servicio de campo en los nodos troncales de La Paz y Cochabamba, y el resto del personal ausente se encontraba cubriendo los turnos nocturnos obligatorios de monitoreo continuo 24/7 en el NOC. Debido a la carga operativa diaria y la falta de personal de relevo, esas personas quedaron pendientes de capacitación y no logramos coordinar un taller de recuperación o re-capacitación específico para ellos.

**Clasificación del Auditor: No Conformidad Menor (NCm)**. Se evidencia una cobertura deficiente del plan (solo el 60-65% de asistencia dentro del área crítica), sin mecanismos de recuperación validados ni registros de justificación formal. Esto vulnera el **Control del Anexo A.6.3** (Concientización, educación y formación en seguridad de la información). **ID del Hallazgo: NCm-02.**

**AUDITOR LÍDER:** Analicemos el flujo de reportes de anomalías. ¿Se registran, clasifican y analizan de manera centralizada la totalidad de los incidentes o eventos sospechosos de seguridad de la información que impactan a la infraestructura de TIGO Bolivia?

**Ing. 1:** Correcto. Contamos con una plataforma corporativa de gestión de tickets de TI. Todos aquellos incidentes calificados como de impacto "Mayor" o "Crítico" —como caídas generalizadas de enlaces MPLS, alertas de denegación de servicio distribuidas o picos inusuales de tráfico perimetral— quedan rigurosamente registrados con su análisis de causa raíz y tiempos de resolución. Ahora bien, las alertas menores, como bloqueos temporales de cuentas por intentos fallidos de login, escaneos superficiales de puertos detectados por firewalls secundarios o infecciones menores aisladas en terminales de desarrollo, comúnmente no se registran en el sistema principal; los ingenieros de turno los solucionan sobre la marcha abriendo una consola y reiniciando el servicio, sin documentarlos para no saturar las métricas de la cola de soporte.

**Clasificación del Auditor: Oportunidad de Mejora (OdM)**. La organización demuestra capacidad operativa para documentar y mitigar las contingencias críticas de alto impacto. No obstante, la omisión sistemática en el registro de eventos y anomalías de menor escala debilita la capacidad de análisis de tendencias y detección temprana de

ataques persistentes avanzados (APT). Control correlacionado: **A.5.29** (Gestión de incidentes de seguridad de la información). **ID del Hallazgo: OdM-01.**

**AUDITOR LÍDER:** Para cerrar esta primera sesión, compártame el documento técnico donde se especifique la política formal de robustez, complejidad, longitud mínima y rotación obligatoria de contraseñas de administración aplicable de forma restrictiva al Sistema Central de Aprovisionamiento y Base de Datos de Clientes.

**Ing 1:** Físicamente no contamos con un documento exclusivo que se titule "Política de Contraseñas del Sistema Core". En la práctica, las plataformas de aprovisionamiento más modernas implementadas recientemente sí obligan técnicamente al usuario a configurar credenciales de alta complejidad. Sin embargo, en los sistemas heredados (*legacy*) y módulos de bases de datos antiguos que siguen operando el núcleo de facturación en tiempo real, el software acepta contraseñas básicas de texto de únicamente 6 u 8 caracteres, no requiere de forma obligatoria caracteres especiales ni mayúsculas, y no tiene parametrizada una fecha de caducidad automática por el temor técnico de que una expiración imprevista altere los scripts de integración automatizada de servicios de la red nacional. Cada ingeniero maneja la clave que ve conveniente para sus actividades.

**Clasificación del Auditor: No Conformidad Mayor (NCM)**. La ausencia de un documento de política unificada y la existencia demostrada de plataformas críticas de producción operando con esquemas de autenticación débiles (longitud insuficiente de 6 caracteres, sin obligatoriedad de complejidad y sin mecanismos técnicos de expiración forzada) viola flagrantemente el **Control del Anexo A.8.5** (Autenticación segura). **ID del Hallazgo: NCM-02.**

### 3.2 DÍA 2 MAÑANA - Inspección física del Data Center Central (Sede Santa Cruz)

- **Fecha y Hora:** Martes 21 de enero 2026 – 08:05 hrs.
- **Técnica Aplicada:** Observación complementada con pruebas de estrés de controles físicos.
- **Acompañante Técnico de TIGO:** Ing. Marcos Luján (Administrador Senior de Infraestructura y Data Center).
- **Auditores en Campo:** Lic. María Torres (Líder) e Ing. Carlos Rojas (Técnico).

A continuación, se detalla la matriz de inspección de los puntos físicos críticos auditados dentro de la instalación del Data Center:

| Punto Específico Inspeccionado | Evidencia Técnica Hallada en Campo por el Equipo Auditor | Nivel CMM | Tipificación del Hallazgo | Control ISO 27001 |
|---|---|---|---|---|
| **Puerta de Acceso Perimetral a las Salas de Servidores Core** | Al inspeccionar el punto de entrada principal al búnker del Data Center, se evidenció que la puerta posee únicamente una cerradura mecánica convencional operada mediante una llave física tradicional. No se dispone de un lector de tarjetas de proximidad RFID, no hay implementado un sistema de autenticación biométrica de doble factor, y se constató la total ausencia de cámaras de videovigilancia enfocadas directamente al punto de apertura exterior. | **1** *(Inicial)* | **No Conformidad Mayor (NCM-03)** | **A.7.2** *(Seguridad física periférica)* |
| **Bitácora y Registro de Visitas al** | El auditor junior solicitó formalmente el | **1** *(Inicial)* | **No Conformid** | **A.7.2** *(Seguridad* |

| Punto Específico Inspeccionado | Evidencia Técnica Hallada en Campo por el Equipo Auditor | Nivel CMM | Tipificación del Hallazgo | Control ISO 27001 |
|---|---|---|---|---|
| **Entorno Tecnológico** | libro de actas o el registro digital de ingresos de personal externo (proveedores, contratistas, auditores). El Administrador del Data Center respondió textualmente: *"Por comodidad llevamos el control de ingresos de forma interna en una hoja de cálculo Excel local en mi laptop, pero en este instante no la tengo abierta ni disponible en esta sala"*. No se encontró ningún registro físico impreso, tableta de firmas o bitácora digital centralizada accesible. | | **ad Mayor (NCM-04)** | *física periférica)* |
| **Control Ambiental e Infraestructura** | Se procedió a la lectura de las pantallas de control de los sensores | **3** *(Definido)* | En Cumplimiento ☑ **[OK]** | **A.7.5** *(Seguridad física y de* |

| Punto Específico Inspeccionado | Evidencia Técnica Hallada en Campo por el Equipo Auditor | Nivel CMM | Tipificación del Hallazgo | Control ISO 27001 |
|---|---|---|---|---|
| **Térmica (Sala A)** | ambientales distribuidos: Temperatura estable a **19.5 °C** y Humedad Relativa controlada en **45.2%**. Los tableros del sistema de alimentación ininterrumpida (UPS) reportaron operación óptima con baterías al 100% de capacidad y balanceo de carga adecuado. Los rangos se encuentran perfectamente alineados con los estándares internacionales de continuidad. | | | *infraestructura)* |
| **Identificación y Etiquetado de Activos de Cómputo** | Se realizó un muestreo aleatorio sobre un bloque de 8 servidores Blade montados en el Rack 04. Se evidenció que 5 de los equipos | **2** *(Repetible)* | ⚠ **No Conformidad Menor (NCm-03)** | **A.8.1** *(Inventario de activos)* |

| Punto Específico Inspeccionado | Evidencia Técnica Hallada en Campo por el Equipo Auditor | Nivel CMM | Tipificación del Hallazgo | Control ISO 27001 |
|---|---|---|---|---|
| | contaban con su etiqueta de inventario correcta. Sin embargo, 3 servidores de alta densidad carecían por completo de cualquier identificación física, código de barras, dirección IP de gestión visible o indicativo del ingeniero responsable de su administración. | | | |
| **Resguardo del Rack Principal de Telecomunicaciones** | El Rack que aloja los switches centrales de distribución de fibra óptica perimetral se encontraba cerrado con llave en su panel frontal. No obstante, al realizar la inspección de detalle, se detectó que la llave de | **1** *(Inicial)* | ⚠ **No Conformidad Menor (NCm-04)** | **A.7.2** *(Seguridad física periférica)* |

| Punto Específico Inspeccionado | Evidencia Técnica Hallada en Campo por el Equipo Auditor | Nivel CMM | Tipificación del Hallazgo | Control ISO 27001 |
|---|---|---|---|---|
| | seguridad mecánica se encontraba **colgada directamente de un gancho adherido al propio rack**, expuesta a la vista y manipulación de cualquier persona o técnico de limpieza que ingrese a la sala común. | | | |
| **Sistema de Circuito Cerrado de Televisión (CCTV) Interno** | Se verificó la existencia de 1 cámara IP de alta definición apuntando a los pasillos fríos de los racks. El auditor técnico solicitó formalmente la exportación de las grabaciones de video correspondientes a los últimos 7 días calendario para validar un acceso específico de mantenimiento. | **2** *(Repetible)* | ⚠ **No Conformidad Menor (NCm-05)** | **A.7.4** *(Monitoreo de la seguridad física)* |

| Punto Específico Inspeccionado | Evidencia Técnica Hallada en Campo por el Equipo Auditor | Nivel CMM | Tipificación del Hallazgo | Control ISO 27001 |
|---|---|---|---|---|
| | Al ingresar a la consola del NVR, se descubrió que el almacenamiento local asignado **solo retiene grabaciones de las últimas 24 horas** debido a una falta de espacio en disco duro, sobreescribiendo el historial e incumpliendo la política interna de TIGO que exige un mínimo de 60 días de retención de video para fines forenses. | | | |
| **Redundancia del Sistema de Climatización Crítica** | Durante el recorrido se constató la operación de un único equipo central de Aire Acondicionado de precisión para toda la sala de servidores core. No se dispone de una segunda unidad | **2** *(Repetible)* | ⚠ **No Conformidad Menor (NCm-06)** | **A.7.5** *(Seguridad física y de infraestructura)* |

| Punto Específico Inspeccionado | Evidencia Técnica Hallada en Campo por el Equipo Auditor | Nivel CMM | Tipificación del Hallazgo | Control ISO 27001 |
|---|---|---|---|---|
| | de respaldo configurada en modalidad espejo ($N+1$). Ante una falla mecánica imprevista o sobrecalentamiento del compresor actual, la temperatura interna escalaría a niveles críticos en menos de 15 minutos, provocando el apagado automático por protección térmica de los switches de la red nacional. | | | |

**3.3 DÍA 2 TARDE Y DÍA 3 - Pruebas técnicas sobre la infraestructura de red core y sistema central de aprovisionamiento (CRM/Billing)**

- **Técnica Aplicada:** Verificación y auditoría técnica basada en evidencia digital irrefutable, ejecución de comandos en consola de comandos y sentencias SQL en entornos vivos de producción.
- **Herramientas y Software Utilizados:** Nmap Security Scanner v7.92, Consola de Administración CheckPoint Firewall, Consultas Directas a Bases de Datos Oracle Database 19c.
- **Responsables Técnicos del Aseguramiento:** Ing. Carlos Rojas (Auditor Técnico) en presencia del Administrador de Redes y el Administrador de Base de Datos (DBA) de TIGO Bolivia.

**PRUEBA TÉCNICA 1 - Escaneo de puertos y servicios abiertos sobre el segmento de red de gestión core (Control A.8.8 - Gestión de vulnerabilidades técnicas)**

El auditor técnico conectó una estación de trabajo de pruebas autorizada a un puerto de red de la DMZ técnica y procedió a lanzar un escaneo agresivo sobre el segmento que aloja las interfaces de administración de los enrutadores y switches principales del núcleo de comunicaciones.

**Comando de consola ejecutado por el auditor:**

Bash

$ nmap -sV -p 1-65535 -T4 --open 10.160.20.0/24

**Resultados y trazas de consola críticas recuperadas de la herramienta:**

Plaintext

Starting Nmap 7.92 ( https://nmap.org ) at 2026-01-21 14:42 Hora oficial de Bolivia

Nmap scan report for core-switch-01.tigo.com.bo (10.160.20.1)

Host is up (0.0012s latency).

PORT STATE SERVICE VERSION

23/tcp open telnet Cisco IOS telnetd (CRÍTICO: Transmisión de comandos en texto plano)

Nmap scan report for gte-traffic-srv.tigo.com.bo (10.160.20.5)

Host is up (0.0021s latency).

PORT STATE SERVICE VERSION

3389/tcp open ms-wbt-server Microsoft Terminal Services (RDP expuesto directamente sin paso por Bastion Host)

Nmap scan report for prov-ftp-02.tigo.com.bo (10.160.20.45)

Host is up (0.0018s latency).

PORT STATE SERVICE VERSION

21/tcp open ftp vsftpd 3.0.3 (Inseguro: Autenticación básica sin TLS/SSL habilitado)

Nmap scan report for internal-billing-app.tigo.com.bo (10.160.20.12)

Host is up (0.0031s latency).

PORT STATE SERVICE VERSION

8080/tcp open http Apache Tomcat 9.0.58 (Interfaz de administración ejecutándose sobre protocolo HTTP tradicional sin cifrado HTTPS)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .

Nmap done: 256 IP addresses (4 hosts up) scanned in 42.15 seconds

📥 **Dictamen de la Prueba Técnica 1 [No Conformidad Mayor - NCM-05]:** El escaneo de puertos en caliente demostró el incumplimiento severo del principio de defensa en profundidad y la ausencia total de un proceso regular de escaneo de vulnerabilidades operativas.

- La presencia del **Puerto 23 (Telnet)** abierto en el switch central del núcleo de red implica que las credenciales de los ingenieros de redes viajan en texto plano por el cableado interno, quedando expuestas a un ataque de interceptación por Sniffing.
- La exposición directa del **Puerto 3389 (RDP)** hacia segmentos accesibles de la red interna inalámbrica corporativa representa el principal vector para el movimiento lateral y despliegue de **Ransomware**.
- **Nivel de Madurez asignado por el Auditor: CMM 1** *(Inicial)*.

**PRUEBA TÉCNICA 2 — Consulta forense y auditoría lógicas de usuarios activos en la Base de Datos Central del Sistema de Aprovisionamiento (Control A.8.2 - Gestión de derechos de acceso)**

El auditor técnico, en acompañamiento mandatorio con el Administrador de Base de Datos (DBA) de la compañía, obtuvo acceso de solo lectura a la consola SQL de producción para auditar la consistencia y vigencia de las cuentas con privilegios avanzados de administración encargadas de activar, suspender o alterar los perfiles de servicios telefónicos y de datos de los clientes.

**Sentencia SQL e instrucciones directas ejecutadas en el motor de base de datos:**

SQL

SELECT username, full_name, date_created, last_login_date, account_status

FROM tigo_core_provis_users

WHERE account_status = 'ACTIVE' AND privilege_level = 'SUPERUSER'

ORDER BY last_login_date DESC;

**Resultado directo de las filas devueltas por el motor transaccional de TIGO:**

Plaintext

+------------+----------------------+-------------+----------------+----------------+

| USERNAME | FULL_NAME | DATE_CREATED | LAST_LOGIN_DATE | ACCOUNT_STATUS |

+----------+----------------------+-------------+----------------+----------------+

| jbenitez | Jorge Benitez (EX-ING) | 2022-03-12 | 2026-01-15 | ACTIVE | <-- CRÍTICO: Ex-empleado con uso reciente

| admin_core | Cuenta Genérica NOC | 2020-01-01 | 2026-01-21 | ACTIVE | <-- CRÍTICO: Cuenta compartida sin trazabilidad

| super_user | Credencial Sistemas | 2021-05-10 | 2026-01-21 | ACTIVE | <-- CRÍTICO: Password por defecto detectado

| mquispe_tl | Marcelo Quispe | 2024-02-18 | 2025-06-02 | ACTIVE | <-- ALERTA: Inactivo por más de 230 días

| arodriguez | Ana Rodriguez | 2025-08-01 | 2026-01-21 | ACTIVE |

+----------+----------------------+-------------+----------------+----------------+

5 rows selected (0.01 seconds)

**Cruce de información inmediata con el área de Recursos Humanos:**

El equipo auditor tomó el primer registro devuelto (jbenitez) y solicitó de forma inmediata al Oficial de Seguridad que verifique el estado contractual de dicha persona. Al revisar los expedientes internos de personal se comprobó lo siguiente: **El Ing. Jorge Benítez presentó su renuncia voluntaria y fue desvinculado formalmente de TIGO Bolivia el 15 de noviembre de 2025.** Su cuenta en el sistema central de aprovisionamiento no solo permanecía en estado 'ACTIVO', sino que la base de datos registra que dicha credencial fue utilizada para iniciar sesión el **15 de enero de 2026**, es decir, dos meses después de su salida de la empresa y exactamente durante el periodo de preparación de esta auditoría.

**Dictamen de la Prueba Técnica 2 [No Conformidad Mayor - NCM-06]:** Se descubrió una brecha de seguridad informática crítica. Un usuario huérfano perteneciente a un ex-empleado mantiene privilegios absolutos de ejecución de comandos (*SUPERUSER*) en el core transaccional y registra actividad operativa no autorizada reciente. Esto viola directamente el principio de menor privilegio, carece de controles de correlación y expone a TIGO Bolivia a responsabilidades legales severas ante la ATT bajo la Ley N° 164. Adicionalmente, el uso generalizado de cuentas compartidas genéricas (admin_core) rompe el principio de no repudio operativo.

- **Nivel de Madurez asignado por el Auditor: CMM 1** *(Inicial).*

**PRUEBA TÉCNICA 3 — Verificación empírica del proceso de respaldo, cifrado y restauración de datos en caliente (Control A.8.13 - Respaldo de la información)**

El auditor técnico solicitó al Ingeniero de Almacenamiento realizar en ese instante una simulación de desastre real, consistente en tomar un archivo dump de respaldo de la base de datos de transacciones financieras de los usuarios (BD_TIGOMONEY_DUMP) generado el 15 de enero de 2026, y proceder a su restauración completa en un entorno

aislado de pruebas, midiendo los tiempos de respuesta y la integridad de los bloques de datos.

- **Responsable de la Ejecución por TIGO:** Ing. Ramiro Flores (Administrador Senior de Sistemas de Almacenamiento).
- **Ubicación del Archivo de Backup de Origen:** Unidad de disco externo USB portátil conectada directamente al servidor físico de la oficina del administrador.
- **Hora de Inicio del Proceso de Restauración:** 14:05 hrs.
- **Hora de Finalización Completa del Proceso:** 17:12 hrs.
- **Tiempo de Recuperación Efectivo (RTO medido):** 3 horas y 7 minutos.

**Métricas de Evaluación de la Prueba de Continuidad:**

- **Validación de Ventana de Tiempo (RTO):** El tiempo medido de 3h 7min se encuentra dentro del Objetivo de Tiempo de Recuperación (RTO) formalmente definido por el negocio para esta plataforma, el cual tiene un tope máximo de **4 horas**. *(Cumplimiento Inicial Parcial).*
- **Análisis de Integridad de Datos:** Al finalizar el script de importación, el sistema de base de datos arrojó dos líneas de error críticas:

Plaintext

ORA-01578: ORACLE data block corrupted (file #4, block #1142)

ORA-01110: data file 4: '/u01/app/oracle/oradata/provis/historial_transacciones.dbf'

Import Process Terminated with Errors: 2 critical logical tables failed to restore.

**Resultado Técnico:** La restauración fue incompleta; dos tablas históricas pertenecientes al registro consolidado de movimientos financieros y transacciones de billetera móvil se encontraban corruptas en el origen, imposibilitando su recuperación y provocando una pérdida potencial neta de información transaccional.

- **Validación de Resguardo Alterno (Offsite Backup):** El auditor técnico constató que el 100% de los respaldos de la infraestructura core se almacenan localmente en la misma sala del Data Center. No se dispone de replicación síncrona o asíncrona hacia un sitio alterno secundario geográficamente distante (ej. un segundo búnker en otra ciudad o nube privada), dejando a TIGO expuesta ante una catástrofe física total en la infraestructura central de Santa Cruz (incendio, sismo o inundación).
- **Evidencia Histórica de Pruebas:** Se solicitó el libro de registro de pruebas preventivas anuales de restauración de backups. El área operativa admitió que **esta simulación forzada por el auditor constituye la primera prueba de restauración real ejecutada sobre dicho archivo en los últimos 10 meses.**

**Dictamen de la Prueba Técnica 3 [No Conformidad Menor - NCm-07]:** Si bien la velocidad de la infraestructura cumple con el margen de tiempo del RTO, el control falla críticamente en su eficacia operativa real: se detectó pérdida de información por corrupción de datos no identificada preventivamente por el equipo, se demostró la total ausencia de un esquema de almacenamiento externo fuera de sitio (*Offsite/Cloud*) y no existe un histórico de pruebas periódicas planificadas.

- **Nivel de Madurez asignado por el Auditor: CMM 2**.

**04 · NIVELES DE MADUREZ CMM - Resultados por control**

**4.1 Tabla consolidada de madurez**

Para cuantificar de forma objetiva la efectividad del SGSI en el **Área de Core Network y Data Centers (ACNDC)** de TIGO Bolivia, el equipo auditor aplicó el Modelo de Madurez de Capacidades (CMM) en una escala de 0 a 5. La asignación de cada nivel se fundamenta estrictamente en las evidencias digitales, físicas y testimoniales recolectadas en campo durante los tres días previos de inspección.

| **Control ISO 27001:2022** | **Nivel CMM** | **Nombre del Nivel** | **Clasificación del Hallazgo** | **Evidencia Técnica que Determina el Nivel** |
|---|---|---|---|---|
| **A.5.1 Políticas para la seguridad de la información** | **3** | **Definido** | En Cumplimiento ☑ **[OK]** | La Política General de Seguridad (PSI-TIGO v2.0) está aprobada por el Comité, es formal y se encuentra publicada en la intranet corporativa (*Workplace*). Es conocida por el 85% del personal administrativo. |
| **A.5.29 Gestión de incidentes de seguridad** | **2** | **Repetible** | Oportunidad de Mejora **(OdM-01)** | El flujo y procedimiento operativo existen en la plataforma de tickets. Los incidentes |

| Control ISO 27001:2022 | Nivel CMM | Nombre del Nivel | Clasificación del Hallazgo | Evidencia Técnica que Determina el Nivel |
|---|---|---|---|---|
| | | | | "Mayores" se mitigan y documentan bien, pero los incidentes "Menores" se resuelven informalmente en consola sin dejar registro ni métrica para análisis forense. |
| **A.6.3 Concientización, educación y formación** | **2** | **Repetible** | No Conformidad Menor **(NCm-02)** | Se ejecutaron talleres presenciales en junio de 2025. Sin embargo, la cobertura fue de apenas el 65% del personal técnico debido a los turnos rotativos del NOC. No se diseñó un plan de recuperación ni evaluaciones post-capacitación. |
| **A.7.2 Seguridad física periférica** | **1** | **Inicial** | No Conformidad Mayor **(NCM-03 / NCM-04)** | Ausencia de controles biométricos o lectores RFID en la entrada del Data Center principal (solo cerradura |

| Control ISO 27001:2022 | Nivel CMM | Nombre del Nivel | Clasificación del Hallazgo | Evidencia Técnica que Determina el Nivel |
|---|---|---|---|---|
| | | | | manual con llave). Inexistencia de un registro formal de visitas centralizado (los ingresos se anotan informalmente en un Excel local no disponible). |
| **A.7.4 Monitoreo de la seguridad física** | **2** | **Repetible** | No Conformidad Menor **(NCm-05)** | La cámara IP dentro de las salas de racks está operativa, pero el almacenamiento asignado en el NVR se encuentra saturado y solo retiene 24 horas de video, destruyendo la evidencia forense e incumpliendo la política interna de 60 días. |
| **A.7.5 Seguridad física de infraestructura** | **2** | **Repetible** | No Conformidad Menor **(NCm-06)** | Sensores de temperatura (19.5 °C) y humedad (45.2%) dentro de rangos operativos óptimos, |

| Control ISO 27001:2022 | Nivel CMM | Nombre del Nivel | Clasificación del Hallazgo | Evidencia Técnica que Determina el Nivel |
|---|---|---|---|---|
| | | | | controlados por UPS funcionales. No obstante, se carece de un sistema de aire acondicionado redundante ($N+1$). |
| **A.8.1 Inventario de activos** | **2** | **Repetible** | No Conformidad Menor **(NCm-03)** | El inventario en software está al 75% de precisión. No se ha actualizado desde julio de 2025 y omite las expansiones de enrutamiento troncal de diciembre. Se hallaron 3 servidores de alta densidad en producción sin etiquetas físicas ni identificación lógica. |
| **A.8.2 Gestión de derechos de acceso** | **1** | **Inicial** | No Conformidad Mayor **(NCM-06)** | La consulta SQL directa reveló una cuenta con privilegios de *SUPERUSER* activa e iniciando sesión a nombre de un ex-ingeniero desvinculado |

| Control ISO 27001:2022 | Nivel CMM | Nombre del Nivel | Clasificación del Hallazgo | Evidencia Técnica que Determina el Nivel |
|---|---|---|---|---|
| | | | | hace dos meses. Se evidenció el uso de cuentas genéricas compartidas sin trazabilidad. |
| **A.8.5 Autenticación segura** | **1** | **Inicial** | No Conformidad Mayor **(NCM-02)** | No existe una política documental unificada de contraseñas para sistemas core. Las plataformas heredadas (*legacy*) aceptan claves de texto plano de solo 6 caracteres, sin obligatoriedad de complejidad y sin expiración técnica parametrizada. |
| **A.8.8 Gestión de vulnerabilidades técnicas** | **1** | **Inicial** | No Conformidad Mayor **(NCM-05)** | El escaneo activo con Nmap en el segmento de gestión core expuso el puerto 23 (Telnet) abierto en el switch de núcleo, el puerto 3389 (RDP) expuesto directamente a la red inalámbrica corporativa y |

| Control ISO 27001:2022 | Nivel CMM | Nombre del Nivel | Clasificación del Hallazgo | Evidencia Técnica que Determina el Nivel |
|---|---|---|---|---|
| | | | | servicios de transferencia FTP sin cifrado TLS. |
| **A.8.13 Respaldo de la información** | **2** | **Repetible** | No Conformidad Menor **(NCm-07)** | El backup local se ejecuta diariamente y el RTO de restauración cumplió el margen (3h 7min). Sin embargo, la prueba arrojó dos tablas críticas financieras corruptas (pérdida de datos) y se constató la total ausencia de un respaldo *offsite* (fuera de sitio). |
| **Cláusula 9.3 Revisión por la dirección** | **0** | **Inexistente** | No Conformidad Mayor **(NCM-01)** | No existe un solo registro, acta firmada, correo de convocatoria o minuta que demuestre que el Comité de Dirección Ejecutiva o la Gerencia General de TIGO Bolivia hayan evaluado |

| Control ISO 27001:2022 | Nivel CMM | Nombre del Nivel | Clasificación del Hallazgo | Evidencia Técnica que Determina el Nivel |
|---|---|---|---|---|
| | | | | el desempeño y los objetivos del SGSI. |

**4.2 Métricas globales del SGSI**

- **Muestra de controles evaluados:** 11 controles del Anexo A + 1 Cláusula Principal (9.3).
- **Nivel CMM Promedio General: 1.58 / 5.0** (Clasificado globalmente entre nivel *Inicial* y *Repetible*).
- **Porcentaje estimado de conformidad con ISO 27001:2022: 46.5%**
- **Consolidado de Hallazgos de Campo:** 6 No Conformidades Mayores (NCM) • 6 No Conformidades Menores (NCm) • 1 Oportunidad de Mejora (OdM).

**Métrica de Control:** Un nivel CMM de 1.58 dictamina técnicamente que TIGO Bolivia cuenta con procesos de seguridad reactivos. Aunque existe una sólida base documental y herramientas tecnológicas de última generación, la ejecución del SGSI depende excesivamente de la iniciativa individual de los operadores de turno en lugar de basarse en políticas institucionales controladas.

**05 · FICHAS COMPLETAS DE HALLAZGOS (Casos Críticos Registrados)**

A continuación, se presentan las fichas técnicas detalladas de los hallazgos más graves detectados por el equipo auditor. Estas fichas siguen rigurosamente la estructura internacional de reporte de desviaciones bajo la norma ISO/IEC 27001:2022.

**FICHA DE HALLAZGO NCM-01**

- **Código del Hallazgo:** TIGO-ACNDC-2026-NCM-01
- **Requisito Normativo Afectado:** Cláusula Principal 9.3 – Revisión por la Dirección.
- **Clasificación del Hallazgo:** No Conformidad Mayor (NCM)
- **Nivel de Madurez Asociado (CMM):** Nivel 0 (Inexistente)

**Evidencia de Auditoría:**

Tras entrevistar al Gerente del ACNDC (Ing. Pedro Quispe) y solicitar las evidencias de gestión a la secretaría del Comité Tecnológico, se constató que no existe ningún acta de reunión, resolución interna, minuta o correo electrónico que certifique que la Alta Dirección o la Gerencia General de TIGO Bolivia hayan revisado formalmente el estado,

los riesgos, las métricas de ciberseguridad y los objetivos del SGSI desde que finalizó su fase de implementación en noviembre de 2025.

**Análisis de Causa Raíz:**

Durante la fase de diseño del SGSI, el equipo de implementación omitió establecer de forma explícita un calendario anualizado de revisiones gerenciales obligatorias. Asimismo, no se capacitó a los miembros del Comité Ejecutivo sobre la obligatoriedad y el impacto regulatorio que posee este requisito para mantener la certificación del operador de telecomunicaciones.

**Evaluación de Riesgo y Operación:**

**CRÍTICO.** La falta de gobernanza por parte de la Alta Dirección impide la asignación presupuestaria prioritaria para la mitigación de brechas de seguridad, rompe el ciclo de mejora continua (PHVA) y deja al SGSI sin dirección estratégica frente a nuevas amenazas regulatorias emitidas por la ATT. Bajo estas condiciones, la certificación internacional bajo ISO 27001 es técnicamente inviable.

- **Prioridad de Atención:** 🔘 ALTA / CRÍTICA (Resolver en los próximos 30 días calendario).

✅ **Plan de Acción Correctiva (PAC) Mandatario:**

1. **Convocatoria Formal:** El CISO de TIGO debe estructurar y convocar de inmediato a una sesión extraordinaria del Comité de Dirección Ejecutiva con una agenda enfocada exclusivamente en los puntos requeridos por la Cláusula 9.3 (estado de acciones previas, cambios en el entorno de riesgos, retroalimentación del SOC y métricas de cumplimiento).
2. **Formalización:** Emitir el *Acta de Revisión Gerencial v1.0* debidamente firmada por el Gerente General y los directores de área, detallando los compromisos y recursos asignados.
3. **Institucionalización:** Modificar el Estatuto del Comité de Ciberseguridad para calendarizar de manera fija revisiones semestrales mandatorias para el resto de la gestión 2026.

- **Responsables Ejecutivos:** Gerente General de TIGO Bolivia + Gerente del AC-NDC.
- **Fecha Límite de Implementación:** 20 de febrero de 2026.

**FICHA DE HALLAZGO NCM-02**

- **Código del Hallazgo:** TIGO-ACNDC-2026-NCM-02
- **Requisito Normativo Afectado:** Control del Anexo A.8.5 – Autenticación segura.
- **Clasificación del Hallazgo:** No Conformidad Mayor (NCM)
- **Nivel de Madurez Asociado (CMM):** Nivel 1 (Inicial)

**Evidencia de Auditoría:**

Verificación directa in situ del software de provisión e interfaces lógicas del núcleo de red. Se comprobó la inexistencia de una política formal documentada de contraseñas. Operativamente, los sistemas heredados (*legacy*) de procesamiento de cobros e integración de red en tiempo real aceptan contraseñas compuestas únicamente por un máximo de 6 caracteres alfabéticos sencillos, no aplican restricciones de complejidad (no exigen mayúsculas ni caracteres especiales) y permiten a los usuarios mantener claves con más de un año de antigüedad sin forzar su expiración o renovación.

**Análisis de Causa Raíz:**

La organización priorizó la estabilidad técnica y la disponibilidad de los scripts automatizados de integración que conectan las plataformas antiguas, evitando deliberadamente la parametrización de directrices de seguridad estrictas ante el temor técnico de que el vencimiento automatizado de una clave interrumpiera la comunicación de los procesos batch nocturnos de facturación.

**Evaluación de Riesgo y Operación:**

**CRÍTICO.** Las credenciales de administración de longitud corta (6 caracteres) y sin complejidad son altamente vulnerables a ataques automatizados de fuerza bruta o descifrado por diccionario ejecutados internamente. El compromiso de una sola de estas cuentas le otorgaría a un atacante la capacidad de alterar perfiles de usuarios, realizar llamadas fraudulentas o desactivar masivamente las cuentas de los clientes a nivel nacional.

- **Prioridad de Atención:** URGENTE (Atender en un plazo máximo de 15 días).

**Plan de Acción Correctiva (PAC) Mandatario:**

1. **Redacción de Política:** Elaborar y aprobar de forma urgente la *Política General de Autenticación y Credenciales Seguras de TIGO*, exigiendo un mínimo de 12 caracteres, uso obligatorio de mayúsculas, minúsculas, números y caracteres especiales (@, #, $, etc.).
2. **Hardening de Plataformas:** Configurar en los servidores de autenticación centralizada (TACACS+/Active Directory) la expiración obligatoria de contraseñas cada 90 días calendario y el bloqueo automático de cuentas tras 3 intentos fallidos de inicio de sesión de forma consecutiva.
3. **Segregación de Cuentas de Servicio:** Separar las contraseñas de los ingenieros humanos de aquellas claves utilizadas por los scripts de automatización (*Service Accounts*), aplicando a estas últimas un esquema de resguardo cifrado en un llavero digital centralizado (*Vault*).

- **Responsables Ejecutivos:** Administrador de Identidades (IAM) + Ingeniero Senior de Core Sistemas.
- **Fecha Límite de Implementación:** 5 de febrero de 2026.

**FICHA DE HALLAZGO NCM-06**

- **Código del Hallazgo:** TIGO-ACNDC-2026-NCM-06
- **Requisito Normativo Afectado:** Control del Anexo A.8.2 – Gestión de derechos de acceso.
- **Clasificación del Hallazgo:** No Conformidad Mayor (NCM)
- **Nivel de Madurez Asociado (CMM):** Nivel 1 (Inicial)

**Evidencia de Auditoría:**

La consulta forense SQL ejecutada directamente sobre el diccionario de datos de la base de datos de aprovisionamiento de producción (tigo_core_provis_users) arrojó que la cuenta identificada con el nombre de usuario jbenitez, parametrizada con el perfil de máximo privilegio (SUPERUSER), se encontraba en estado 'ACTIVE'. Al contrastar esta fila con los registros oficiales de la Gerencia de Capital Humano, se evidenció que el Ing. Jorge Benítez cesó sus funciones y fue desvinculado de TIGO Bolivia el 15 de noviembre de 2025. El log histórico de conexiones demuestra que dicha cuenta registró inicios de sesión exitosos el **15 de enero de 2026**, dos meses después de la salida oficial de la persona de la compañía.

**Análisis de Causa Raíz:**

El proceso de baja de personal opera mediante flujos informales basados en tickets manuales en la mesa de ayuda, sin una vinculación de software parametrizada o notificaciones automáticas inmediatas entre el sistema operativo de Recursos Humanos y las consolas de administración lógicas del Core de red.

**Evaluación de Riesgo y Operación:**

**CRÍTICO.** Representa un acceso no autorizado flagrante a infraestructura crítica de telecomunicaciones nacional y datos de carácter privado de millones de abonados. El control de accesos lógicos está roto en su base operativa. Expone a TIGO a multas económicas millonarias por parte de la ATT debido al incumplimiento de los deberes de custodia estipulados en la Ley N° 164, además de un riesgo inminente de sabotaje de red, espionaje corporativo o exfiltración masiva de información confidencial.

- **Prioridad de Atención:** INDUSTRIAL / INMEDIATA (Solución obligatoria en 48 horas).

**Plan de Acción Correctiva (PAC) Mandatario:**

1. **Bloqueo de Emergencia (Primeras 24 horas):** Inhabilitar y purgar inmediatamente del sistema central la cuenta jbenitez y las cuentas compartidas genéricas detectadas que carezcan de un responsable humano unívoco.
2. **Auditoría de Depuración:** Ejecutar un script de cruce masivo automatizado entre el 100% de la plantilla de personal activo reportada por Planillas de RRHH contra el 100% de los usuarios creados en los switches core, enrutadores troncales y bases de datos transaccionales, dando de baja inmediata cualquier cuenta huérfana.

3. **Automatización del Proceso de Baja:** Diseñar e implementar una interfaz de software obligatoria (API) que conecte el sistema de gestión de personal de RRHH con el orquestador central de identidades. En el mismo minuto en que se procese el finiquito de un empleado, el software debe revocar de manera síncrona y automática la totalidad de sus tokens de acceso y credenciales de red.

- **Responsables Ejecutivos:** Administrador de Base de Datos Core + Director de Capital Humano + Administrador de Seguridad de Red.
- **Fecha Límite de Implementación:** 48 horas para desactivación inmediata de cuentas anómalas; 30 días para la integración automatizada del proceso de baja de usuarios.

**06 · EXTRACTO DEL INFORME FINAL - Resumen Ejecutivo para la Alta Dirección**

**6.1 Datos generales del informe**

- **Referencia del Documento:** AI-TIGO-ACNDC-2026-001
- **Fecha de Emisión Formal:** 31 de enero de 2026
- **Clasificación de Seguridad: CONFIDENCIAL / SECRETO INDUSTRIAL** – Distribución restringida exclusivamente a los miembros del Comité de Dirección, la CISO y la Gerencia de Core Network de Telecel S.A.
- **Firma Autorizada:** Lic. María Torres – Auditor Líder en Seguridad de la Información (Certificación ISO 27001 LA).

**6.2 Resumen cuantitativo de resultados**

[ Hallazgos Totales Detectados: 13 ]

├── No Conformidades Mayores (NCM): 6 ————> Requieren Cierre Obligatorio Inmediato

├── No Conformidades Menores (NCm): 6 ————> Plazo de Subsanación en Auditoría de Seguimiento

└── Oportunidades de Mejora (OdM): 1 ————> Recomendación Proactiva de Optimización

- **Nivel de Madurez Promedio (CMM): 1.58 / 5.00**
- **Porcentaje de Alineación y Conformidad Global: 46.5%**
- **Recomendación de Certificación Externa: DENEGADA / RECHAZADA.** La organización posee vulnerabilidades críticas en la operación viva que impiden someterse a una auditoría de certificación internacional en la ventana actual de tiempo.

**6.3 Conclusión del Auditor Líder**

"El Sistema de Gestión de Seguridad de la Información de TIGO Bolivia (Telecel S.A.) demuestra un esfuerzo notable y de alto nivel en su dimensión documental y estratégica:

la Política de Seguridad de la Información, la Declaración de Aplicabilidad (SoA) y la Matriz de Riesgos se encuentran correctamente diseñadas, alineadas formalmente con el negocio y firmadas. No obstante, se ha identificado una brecha profunda y de alto riesgo entre las directrices plasmadas en el papel y la realidad técnica operativa que se vive en los laboratorios y salas del Core Network en Santa Cruz.

Los hallazgos de carácter Mayor documentados en este informe —específicamente la persistencia de cuentas de ex-funcionarios con máximos privilegios operativos registrando accesos recientes, la exposición perimetral interna de puertos administrativos altamente inseguros como Telnet sin cifrar en switches de núcleo, y la total ausencia de un control de supervisión por parte de la Alta Dirección— constituyen debilidades estructurales que colocan la continuidad del servicio de telecomunicaciones nacional y la privacidad de los datos financieros de los clientes en un estado de vulnerabilidad inaceptable.

En consecuencia, **se dictamina que el SGSI auditado no se encuentra listo para iniciar el proceso de Certificación Externa bajo ISO/IEC 27001:2022.** La organización debe concentrar sus capacidades técnicas de forma inmediata en ejecutar el Plan de Acción Correctiva adjunto. Se estima que, con la inyección de los recursos tecnológicos adecuados y aplicando la automatización de controles lógicos detallada, TIGO Bolivia podría alcanzar un Nivel de Madurez 3 (Definido) en un periodo de **60 a 90 días**, habilitando en ese momento la reapertura del proceso de certificación con plenas garantías de resiliencia."

— **Lic. María Torres**, Lead Auditor ISO/IEC 27001.

### 6.4 Plan de Acción Correctiva (PAC) - Matriz de Resumen Operativo

La siguiente tabla resume el cronograma maestro de remediación que la organización debe desplegar de manera mandatoria, asignando líderes y plazos perentorios para levantar los hallazgos de la auditoría.

| ID Hallazgo | Control / Cláusula Afectada | Acción Correctiva Mandataria a Desplegar | Ingeniero Responsable | Plazo Máximo de Cierre |
|---|---|---|---|---|
| **NCM-01** | Cláusula 9.3 | Convocar sesión del Comité Ejecutivo, procesar el primer Tablero de Desempeño del SGSI y firmar el Acta de Revisión de la Dirección Ejecutiva. | Gerente General + CISO TIGO | 30 Días |

| ID Hallazgo | Control / Cláusula Afectada | Acción Correctiva Mandataria a Desplegar | Ingeniero Responsable | Plazo Máximo de Cierre |
|---|---|---|---|---|
| **NCM-02** | Control A.8.5 | Aprobar la Política de Contraseñas Core, forzar técnicamente una longitud mínima de 12 caracteres complejos e implementar el bloqueo por intentos fallidos. | Administrador de Identidades (IAM) | 15 Días |
| **NCM-03** | Control A.7.2 | Desmantelar cerraduras mecánicas ordinarias en las puertas del Data Center e instalar lectores biométricos con control de acceso por doble factor. | Gerente de Infraestructura Física | 30 Días |
| **NCM-04** | Control A.7.2 | Implementar una aplicación o sistema digital centralizado para el control de visitas al búnker técnico, prohibiendo registros en Excels locales. | Administrador Senior de Data Center | 10 Días |
| **NCM-05** | Control A.8.8 | **Cierre inmediato de puertos críticos:** Bloquear el puerto 23 (Telnet) en switches core, migrar la administración a | Ingeniero Senior de Seguridad de Red | **48 Horas** |

| ID Hallazgo | Control / Cláusula Afectada | Acción Correctiva Mandataria a Desplegar | Ingeniero Responsable | Plazo Máximo de Cierre |
|---|---|---|---|---|
| | | SSHv2 cifrado, cerrar el puerto 3389 expuesto e implementar VPN con MFA. | | |
| **NCM-06** | Control A.8.2 | **Bloqueo inmediato de la cuenta huérfana jbenitez.** Diseñar una API automatizada que vincule el software de RRHH con el Active Directory corporativo. | Administrador de Base de Datos + Director de Capital Humano | **48 Horas** *(Bloqueo)*<br><br>30 Días *(API)* |
| **NCm-01** | Control A.8.2 | Establecer un acuerdo de nivel de servicio (SLA) mandatorio por política para la desactivación de cuentas estándar en un tope máximo de 2 horas tras la salida de personal. | Administrador de Identidades (IAM) | 15 Días |
| **NCm-02** | Control A.6.3 | Desarrollar módulos de capacitación virtual (*e-Learning*) obligatorios con evaluaciones automatizadas para el personal técnico con turnos nocturnos del NOC. | Especialista de Capacitación RRHH | 40 Días |

| ID Hallazgo | Control / Cláusula Afectada | Acción Correctiva Mandataria a Desplegar | Ingeniero Responsable | Plazo Máximo de Cierre |
|---|---|---|---|---|
| **NCm-03** | Control A.8.1 | Ejecutar un barrido de red para actualizar el Inventario de Activos lógicos e imprimir etiquetas físicas con códigos QR para los 3 servidores Blade huérfanos. | Administrador de Infraestructura TI | 20 Días |
| **NCm-05** | Control A.7.4 | Ampliar la capacidad de almacenamiento en discos duros del NVR de videovigilancia para garantizar de forma estricta la retención histórica de 60 días de video. | Especialista de Soporte Técnico CCTV | 15 Días |
| **NCm-06** | Control A.7.5 | Elaborar el proyecto de factibilidad financiera para la adquisición e instalación de una segunda unidad de aire acondicionado de precisión para redundancia $N+1$. | Gerente de Infraestructura Física | 60 Días |
| **NCm-07** | Control A.8.13 | Configurar una rutina automatizada diaria de replicación de backups en una nube privada | Administrador de Almacenamiento | 30 Días |

| ID Hallazgo | Control / Cláusula Afectada | Acción Correctiva Mandataria a Desplegar | Ingeniero Responsable | Plazo Máximo de Cierre |
|---|---|---|---|---|
| | | ubicada en una región geográfica distinta. Corregir bloques corruptos. | | |
| **OdM-01** | Control A.5.29 | Rediseñar el flujo de la mesa de ayuda para obligar al registro del 100% de los incidentes menores, construyendo un Dashboard analítico automatizado. | Responsable del SOC de TIGO | 45 Días |

## 07 · LECCIONES APRENDIDAS Y CONCLUSIONES ACADÉMICAS

La ejecución de este caso simulado de auditoría interna integral sobre la infraestructura crítica de **TIGO Bolivia (Telecel S.A.)** aporta conclusiones metodológicas esenciales tanto para el perfil del auditor informático moderno como para la gestión de la ciberseguridad industrial en entornos corporativos de alta demanda.

### 7.1 Para el Auditor de Sistemas

- **El Mito del Cumplimiento Documental:** Queda empíricamente demostrado que la existencia de políticas estéticamente impecables y manuales de procedimientos aprobados formalmente por comités ejecutivos no correlaciona necesariamente con la seguridad real en las trincheras operativas. El papel soporta cualquier directriz; la infraestructura de producción viva no. El auditor debe poseer un perfil técnico punzante para confrontar los documentos con la realidad digital.
- **La Fuerza de la Evidencia Técnica Irrefutable:** El uso de técnicas de auditoría avanzadas, como consultas directas a los diccionarios de datos de los motores de bases de datos transaccionales (SELECT en SQL) y escaneos de red activos con herramientas forenses (Nmap), proporciona pruebas objetivas de carácter irrefutable. Ante una traza de consola que expone credenciales viajando en texto plano por Telnet o un log que registra actividad de un ex-empleado, el auditado no tiene margen de ambigüedad para refutar el hallazgo.
- **Gobernanza como Criterio de Éxito:** Un auditor nunca debe limitar su alcance a revisar servidores y switches. Si la Alta Dirección (Gobernanza) está desconectada del SGSI, el sistema está destinado a degradarse de manera reactiva y a fallar

ante el primer examen de certificación. La revisión por la dirección (Cláusula 9.3) es el verdadero motor político y financiero del marco ISO 27001.

### 7.2 Para la Organización Auditada (TIGO Bolivia)

- **Ciberseguridad es Operación Diaria, no un Proyecto de 9 Meses:** La seguridad de la información no concluye cuando se entrega el proyecto de consultoría y se archivan los manuales v1.0. El SGSI requiere mantenimiento, supervisión constante, actualización dinámica de inventarios y una disciplina estricta en el cumplimiento de los procesos diarios por parte de los operadores del NOC y SOC.
- **La Automatización como Salvaguarda Crítica:** En organizaciones complejas que gestionan millones de usuarios y cientos de empleados técnicos, los flujos basados en notificaciones manuales, llamadas telefónicas o tickets informales para dar de baja cuentas representan un riesgo crítico inaceptable. Los controles de identidad deben estar completamente integrados a nivel de software mediante APIs automatizadas para eliminar el factor del error o retraso humano.
- **La Auditoría Interna como Aliado Estratégico de Mejora:** La detección de 6 No Conformidades Mayores en este informe no debe interpretarse bajo ninguna circunstancia como un fracaso del equipo técnico. Al contrario, la auditoría interna opera como un escáner preventivo de salud institucional que detecta las brechas de seguridad en un entorno controlado, permitiendo su remediación oportuna antes de que un ciberdelincuente real explote dichas vulnerabilidades, evitando un impacto catastrófico en la reputación corporativa de la empresa y sanciones financieras severas por parte de los entes reguladores como la ATT.